SecureWV

In partnership with



SWV Labs Working with the CSF

Author: @MicahKBrown

Goal: The goal is to give you hands-on experience working with the NIST Cyber Security Framework! The main goal is to help you identify which domain(s) are applicable to various cybersecurity concepts and tools.

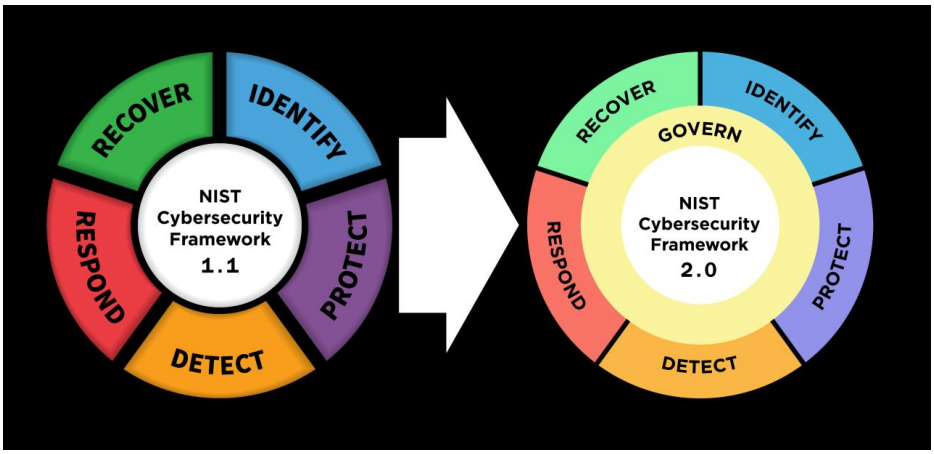
Pre Requirements:

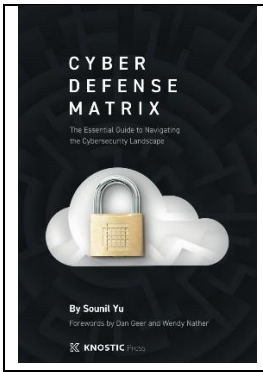
- Bring a pencil.

Getting Started:

> "The NIST Cybersecurity Framework (CSF) 2.0 provides guidance to industry, government agencies, and other organizations to manage cybersecurity risks. It offers a taxonomy of highlevel cybersecurity outcomes that can be used by any organization — regardless of its size, sector, or maturity — to better understand, assess, prioritize, and communicate its cybersecurity efforts. The CSF does not prescribe how outcomes should be achieved. Rather, it links to online resources that provide additional guidance on practices and controls that could be used to achieve those outcomes. This document describes CSF 2.0, its components, and some of the many ways that it can be used."
> NIST CSF 2.0 Abstract: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

At this time most many organizations are still using version 1.1 which contains 5 domains. A newer version 2.0 was released earlier this year that adds a new Govern Domain. However, upon closer investigation it is found the vast majority of the requirements from the Govern domain today were rehomed from the other 5 domain in previous versions.



	I would like to take a moment to acknowedge that this session is base on the a session that I attended at RSA Confrence a few years back by Sounil Yu. If you are interested in learning parcticle ways to work with and withing the NIST CSF I strongly recomend his book to you. A quick search on youtube.com will show severl of his talks. At the time where he created his book NIST was still pre v2.0 published so the domain of Govern does not exist. However I do not think that this is that big of deal for the way he works with the CSF focuses least on the domain of Govern. For that reason I have choosen not to include a govern domain in our retelling of this concept.

For this lab we will be using CFS v1.1.

While Sounil Yu by default used the categories of Device, Network, Application, Data, and Users as the default grouping in his Cyber Defense Matrix we strongly recommend that you customize these grouping to meet your needs. For Example:

- A company that acquires a bunch of other companies can easily find itself using multiple different tool to address the same same threats. This not only adds to complexity but does not allow you to reduce total spend cost by unification of tools through volume costs licensing. Thus having a grouping by company could help show gaps and overlaps and help make strategic decisions.
- It would also help identify differences in geolocations.
- Compare different network zones / applications.
- Compare and contrast protections across different org roles (Executives, High Value Targets [Management, Legal, HR], Privileged users, standard users)

This framework is highly flexible and can be used to craft a story that can easily be understood by all steak holders.

NIST CSF v1.1 Domains:

Identify – Develop an organizational understanding to manage cybersecurity risk to systems, people, assets, data, and capabilities. The activities in the Identify Function are foundational for effective use of the Framework. Understanding the business context, the resources that support critical functions, and the related cybersecurity risks enables an organization to focus and prioritize its efforts, consistent with its risk management strategy and business needs. Examples of outcome Categories within this Function include: Asset Management; Business Environment; Governance; Risk Assessment; and Risk Management Strategy.

Protect – Develop and implement appropriate safeguards to ensure delivery of critical services. The Protect Function supports the ability to limit or contain the impact of a potential cybersecurity event. Examples of outcome Categories within this Function include: Identity Management and Access Control; Awareness and Training; Data Security; Information Protection Processes and Procedures; Maintenance; and Protective
Technology.

Detect – Develop and implement appropriate activities to identify the occurrence of a cybersecurity event. The Detect Function enables timely discovery of cybersecurity events. Examples of outcome Categories within this Function include: Anomalies and Events; Security Continuous Monitoring; and Detection Processes.

Respond – Develop and implement appropriate activities to take action regarding a detected cybersecurity incident. The Respond Function supports the ability to contain the impact of a potential cybersecurity incident. Examples of outcome Categories within this Function include: Response Planning; Communications; Analysis; Mitigation; and Improvements.

Recover – Develop and implement appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident. The Recover Function supports timely recovery to normal operations to reduce the impact from a cybersecurity incident. Examples of outcome Categories within this Function include: Recovery Planning; Improvements; and Communications.

Source NIST CSF: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf

East / West Demarcation:

One of the most brilliant things that Sounil did was that he visually ordered his Cyber Defense matrix in such a way that #Identify and #Protect are WEST of the demarcation line and #Detect, #Respond, and #Recover are to the east. demarcation line. What this does is that it helps us correctly work earlier with the CSF. Everything to the left / west of the line of demarcation is something that is being done BEFORE and event. Everything else to the right / east of the demarcation line is something that is being done AFTER an even.



Lab Instructions:

Collectively we are going to work our way though a list of controls / technologies and not only define which of the 5 v1.1 CSF domains it fits in but also does it primary apply to Devices, Networks, Applications, Data, or Users.

The goal is not to get though all of these but to go through and have meaningful conversations on the ones that we go though.

List of Controls & Technologies:

Allowlisting

Allowlisting is a cybersecurity strategy that limits access to a system by only allowing pre-approved applications, processes, IP addresses, or email addresses to run.

Anti Virus (AV)
Antivirus software is a cybersecurity tool that protects devices and networks from malicious software, also known as malware. It scans for patterns that indicate the presence of malware, such as viruses, worms, trojan horses, spyware, adware, and ransomware.

Application detection and response (ADR)
ADR provides security teams with a powerful tool to defend custom and self-hosted third-party applications against exploits. It leverages software instrumentation to directly observe the behavior of web applications and application programming interfaces (APIs) at runtime, continuously monitoring the applications for behavioral anomalies. The ADR tool not only provides real-time visibility into malicious activity at the application layer, but it also provides compensating controls that prevent attempts to exploit existing vulnerabilities.

Asset MGMT
The process of identifying, classifying, and managing an organization's IT assets to mitigate security risks.

Background check
A legal investigation that verifies a candidate's background and identity to confirm they are a trustworthy and responsible employee.

Breach Response
The process and procedures to acquire, process, and validate data recover as part of a Breach Response.

Certificate MGMT
Certificate Management is a welll-defined lifecycle—they are issued, used, and retired.

Classification
Classification management is the process of managing the life cycle of classified information / devices, from its original classification to its declassification based on defined / observed attributes.

Data Audit
A comprehensive evaluation of an organization's data security practices, systems, and controls to identify potential vulnerabilities and weaknesses that could expose sensitive information, aiming to prevent data breaches and ensure compliance with relevant regulations.

Data Detection and Response (DDR)
A technology solution that actively monitors and analyzes data across an organization to detect potential threats targeting sensitive information in real-time, allowing for swift responses to mitigate data breaches and minimize damage before significant harm occurs.

Data Leak Discovery (DLD)
The practices and tools used in and technologies used to stop sensitive information from being unintentionally or maliciously leaked, lost, or exposed

Data Loss Prevention (DLP)
a cybersecurity solution that helps organizations protect sensitive data from being lost, misused, or accessed by unauthorized users.

DDoS Response

The set of actions taken and tools used by an organization to mitigate and recover from a Distributed Denial-of-Service (DDoS) attack.

Deep Web Analysis
The process and tools that assist in actively scanning and investigating the "Deep Web" - a part of the internet not indexed by standard search engines, to identify potential threats, data breaches, or sensitive information that might be exposed on hidden online forums, marketplaces, or databases, often requiring specific login credentials to access

Digital Rights MGMT (DRM)
The use of technology to control access to copyrighted / company-owned material

Discovery
Electronic discovery, or eDiscovery, refers to discovery in which the information sought is in electronic format and tools that are used by it.

Emergency Preparedness Forensics (EPF)
The practice and tools use in performing digital forensics techniques to investigate and gather evidence during an emergency situation.

Emergency Preparedness Response (EPR)
the proactive measures and plans put in place by an organization to prepare for, respond to, and recover from potential emergencies and the tools that are used.

Encryption
A data security method that protects sensitive information by converting it into a secret code that can only be accessed by authorized users with a key

End User Behavior Analytics (EUBA)
The practice of monitoring and analyzing the digital actions of individual users within a system to identify unusual activity that could potentially indicate a security threat

Endpoint Detection
A cybersecurity practice that monitors and protects devices that connect to a network, also known as endpoints

Extended Detection and Response (XDR)
A cybersecurity technology that collects and correlates data from multiple security layers across an organization's IT infrastructure, like endpoints, networks, cloud, and email, to provide a unified view of potential threats, enabling faster and more accurate detection and response to complex cyberattacks.

File Integrity Monitoring (FIM)
A security practice that involves continuously checking and verifying the integrity of critical system files, like operating system and application files, by comparing their current state to a known "baseline" to detect any unauthorized changes or potential tampering.

Fuzzers
A software testing technique that uses a fuzzer tool to identify security vulnerabilities and coding errors in software, operating systems, or networks.

Insider Threat
The threat that an insider will use their authorized access, intentionally or unintentionally, to do harm to the department's mission, resources, personnel, facilities, information, equipment, networks, or systems.

IPS / IDS
A network security device that monitors and filters incoming and outgoing network traffic based on a previously established security policies intended to detect malicious patterns in network traffic. IDS can only alert on bad activity. IPS can automatically stop bad activity if it hits a certain threshold.

Micro segmentation
A cybersecurity technique that divides a network into smaller, more secure zones to limit access to resources and improve security.

Netflow
A network protocol developed by Cisco for collecting IP traffic information and monitoring network flow.

MFA
a security method that requires users to provide more than just a password to log in to an account

Network Forensics (NetF)
A process that involves analyzing network traffic to identify security threats, troubleshoot network issues, and track down cyberattack perpetrators.

Network Traffic Analysis (NTA)
The process of monitoring and analyzing network data to identify unusual activity, potential security threats, and malicious behavior by examining the flow of traffic across a network.

Network Vuln Scanner
A cybersecurity tool that actively scans a network to identify potential security weaknesses, like open ports, outdated software, or misconfigurations.

Phishing Simulation
A fake phishing email or other cyber threat that an organization sends to employees to assess their knowledge of phishing attacks and test their online behavior.

Runtime Application Self Protection (RASP)
A tool that can detect attacks on applications as they occur. A RASP implementation can protect applications from malicious data and behavior by analyzing how the program behaves. If the application's behavior indicates something is wrong, RASP can help stop the threat.

Security / Awareness Training
Security awareness training is a way to educate employees and other authorized users on how to protect themselves and their organization's assets from cyber threats.

SOAR
A collection of software programs that help organizations manage and respond to security threats.

Software Asset MGMT

The practice of managing and monitoring an organization's software assets throughout their lifecycle to minimize security risks by identifying and addressing vulnerabilities associated with outdated, unauthorized, or improperly configured software, ensuring compliance with licensing agreements, and optimizing software usage across the organization.

Source Code Compromise (SCC)
A tool that helps detect when attacker gains unauthorized access to the underlying code of a software application, potentially exposing sensitive information like algorithms, proprietary technology, API keys, or other critical details, which can lead to severe security vulnerabilities, intellectual property theft, and potential exploitation of flaws within the code itself.

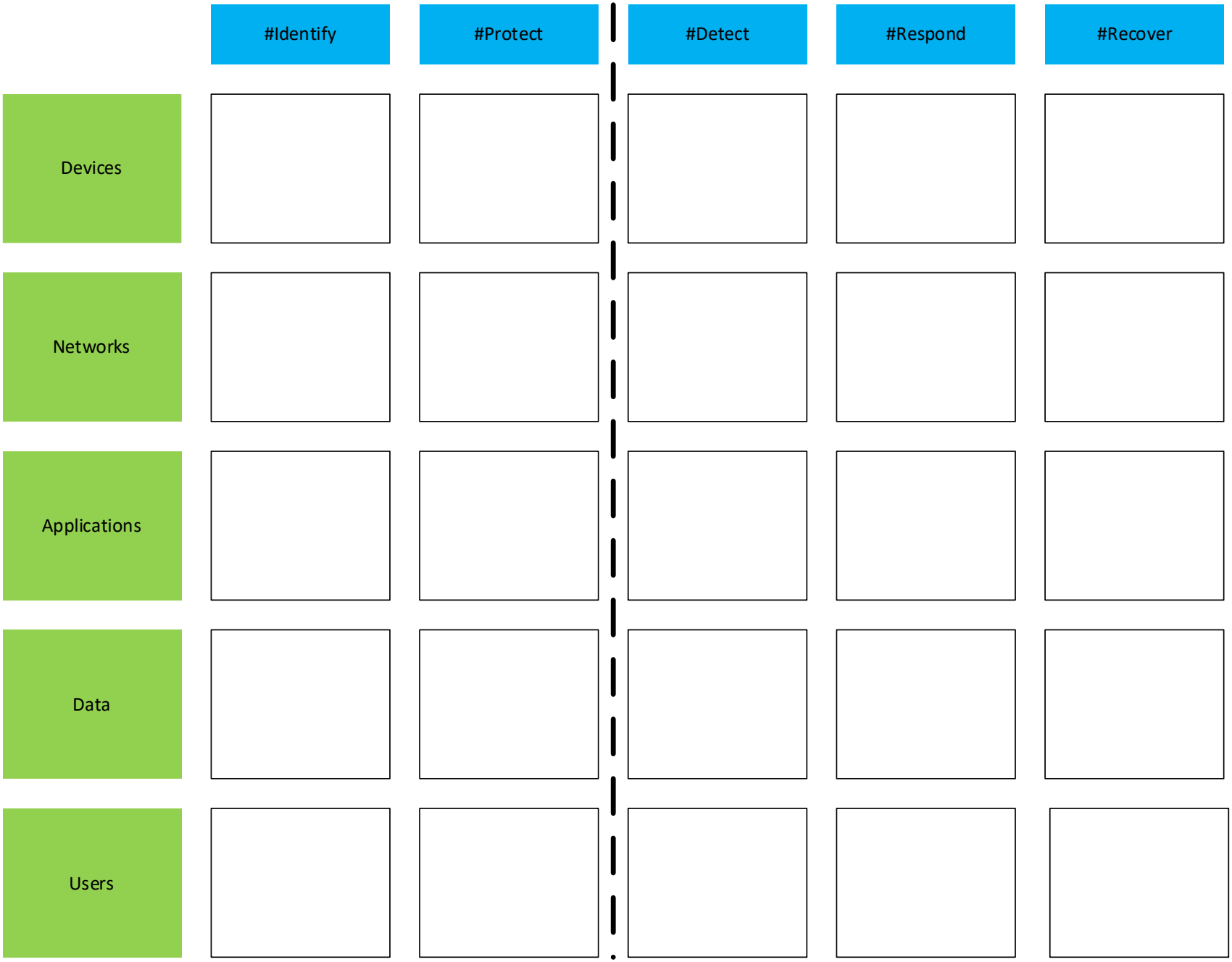
Static Application Security Testing (SAST)
A software testing method that analyzes an application's source code to identify potential security vulnerabilities early in the development lifecycle, without actually running the application, essentially acting as a "known-architecture" testing approach to find security flaws within the code itself, like SQL injection, cross-site scripting (XSS), and insecure data handling, before they become part of a deployed application.

Tokenization
The practice of protecting sensitive data by replacing it with a token — a unique and nonsensitive string of symbols randomly generated by an algorithm that has no meaning or exploitable value.

Vuln MGMT
A security practice that helps organizations identify, assess, and fix potential security weaknesses in their systems and software.

Zero Trust Access Proxy (ZTAP)
A security mechanism that acts as a gateway, enforcing strict identity verification and context-based access controls before allowing users to connect to applications or resources.

Zero Trust Networking Access (ZTNA)
A security mechanism that acts as a gateway, enforcing strict identity verification and context-based access controls before allowing users to connect to applications or resource.


#Identify
#Protect
#Detect
#Respond
#Recover
Devices
Networks
Applications
Data
Users